



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



ISO/IEC 27001 vs OT: Adaptación de controles en entornos industriales

Y su relación con ISA/IEC 62443 y NIST CSF

Módulo 7



ISO/IEC 27001 vs OT

Introducción: dos mundos que convergen

La norma **ISO/IEC 27001** es un estándar internacional ampliamente adoptado para establecer un **Sistema de Gestión de Seguridad de la Información (SGSI)** en entornos IT.

Sin embargo, cuando se aplica en entornos **OT (Operational Technology)**, como plantas industriales, infraestructuras críticas o sistemas SCADA, surgen **retos específicos**.

¿Por qué? Porque OT y IT **tienen prioridades diferentes**:

Área	IT	OT
Prioridad	Confidencialidad	Disponibilidad y seguridad física
Ciclo de vida	Corto, adaptable	Largo (10-30 años), difícil de actualizar
Entornos	Cambiantes, virtuales	Estables, físicos y controlados
Incidentes	Pérdida de datos	Parada de producción, riesgo humano

ISO/IEC 27001 vs OT

¿Qué es la ISO/IEC 27001?

- Norma para establecer, implementar, mantener y mejorar un **SGSI**.
- Se basa en el ciclo PDCA (**Plan-Do-Check-Act**).
- Incluye **114 controles organizativos, técnicos y físicos** (Anexo A de la versión 2013; versión 2022 reorganiza en 4 grupos y 93 controles).

¿Qué es ISA/IEC 62443?

- Es la norma **específica de ciberseguridad industrial**.
- Define controles y buenas prácticas para entornos OT: desde componentes individuales (PLC, RTU, sensores) hasta procesos de gestión.
- Desarrollada por ISA, adoptada como IEC 62443 por la Comisión Electrotécnica Internacional.

ISO/IEC 27001 vs OT

¿Se puede aplicar ISO/IEC 27001 en entornos OT??

Sí, pero **requiere adaptación**:

A. Aspectos adaptables

- Gestión de riesgos
- Gestión documental
- Concienciación
- Gestión de incidentes
- Gestión de accesos

B. Aspectos que requieren adaptación o enfoque mixto

- Gestión de cambios (más rigidez en OT)
- Controles físicos (planta ≠ oficina)
- Monitorización (sin afectar disponibilidad)
- Cifrado (evitar latencias en tiempo real)

ISO/IEC 27001 vs OT

¿Se puede aplicar ISO/IEC 27001 en entornos OT??

- **C. Controles ISO 27001 más sensibles en OT:**
- **Control A.12.4.1:** Registros y monitorización de eventos (impacto en PLCs si mal implementado).
- **A.9.2.3:** Gestión de derechos de acceso de usuarios (¿cómo gestionar accesos compartidos en planta?).

Estrategia de integración

- **Enfoque mixto recomendado:**
- Usar ISO/IEC 27001 como **marco de gestión general**.
- Integrar controles específicos de **IEC 62443** para la parte técnica en entornos industriales.
- Alinear todo con marcos reconocidos como **NIST CSF** (Cybersecurity Framework).
- Planificación de continuidad (debe integrarse con planes industriales, no solo IT).

ISO/IEC 27001 vs OT

Maapeo entre ISO 27001, IEC 62443 y NIST CSF

- El **NIST Cybersecurity Framework (CSF)** es ampliamente usado para alinear marcos IT y OT.
- El NIST ha publicado documentos de **mapping cruzado** entre:
- **ISO/IEC 27001** ↔ NIST CSF
- **ISA/IEC 62443** ↔ NIST CSF

¿Qué permite esto?

- Entender cómo un control de ISO 27001 se corresponde con funciones del NIST CSF (Govern, Identify, Protect, Detect, Respond, Recover).
- Identificar qué controles industriales (IEC 62443) se alinean con cada función.

ISO/IEC 27001 vs OT

Maapeo entre ISO 27001, IEC 62443 y NIST CSF

- Ejemplo de mapeo (simplificado):

NIST CSF Function	ISO/IEC 27001 Control	ISA/IEC 62443 Requisito
Identify	A.6.1.1: Roles y responsabilidades	2-1-1: Security policy
Protect	A.9.2.1: Gestión de accesos	3-3-2: Authentication control
Detect	A.12.4.1: Registro de eventos	3-3-5: Intrusion detection
Respond	A.16.1.1: Gestión de incidentes	2-4-1: Security incident response planning
Recover	A.17.1.1: Plan de continuidad	2-4-3: Backup and recovery

Este mapping permite desarrollar un sistema híbrido que cumpla con ISO 27001 y 62443 a la vez, facilitando auditorías cruzadas.

ISO/IEC 27001 vs OT

Factores críticos de éxito en la aplicación en OT

- ✓ Involucrar al personal OT desde el inicio
- ✓ Adaptar el lenguaje de los controles al entorno industrial
- ✓ Asegurar que las medidas no afectan la disponibilidad
- ✓ Tener una política clara de cambio y validación
- ✓ Integrar el SGSI con sistemas de gestión de calidad (ISO 9001) o seguridad operacional (ISO 45001)

Ejemplo práctico de implementación

- Una planta química decide certificar ISO 27001 su red IT, y aplicar IEC 62443 a sus sistemas SCADA.
- Crea un único SGSI con políticas comunes.
- Divide claramente los activos OT/IT.
- Aplica controles ISO 27001 sobre riesgos comunes y 62443 sobre riesgos OT específicos.
- Elabora un **Análisis de Riesgos integrado** siguiendo ambos marcos.